

Actividad 01

ANÁLISIS Y PLANIFICACIÓN DEL PENTEST

Escenario: Aurora Market

Liz Madelyne Tumbaco Peñafiel

Hacker Woman Council - Ethical Hacking



1. Objetivo del Pentest

Objetivos específicos de la evaluación:

- Identificar algún tipo de vulnerabilidad de seguridad presentes en la aplicación web de Aurora Market que puedan ser aprovechadas por un atacante.
- Evaluar el riesgo, impacto que tendría la explotación de las vulnerabilidades sobre la información, usuarios, pedidos y funcionalidades de la plataforma.
- Proponer las mejores prácticas para de seguridad para reducir los riesgos que se han identificado y fortalecer la protección del aplicativo y de los datos de los clientes.

2. Alcance

Se evaluará

- Aplicación web de Aurora Market, la cual se brinda una autorización previa por parte de la entidad.
- Metodos de autenticación y gestión de sesiones.
- Registro, inicios de sesiones de usuarios, controles de acceso y autorización.
- Procesos dentro del aplicativo que tengan relacion con productos, compras y pedidos.

Fuera del alcance

- Cuentas de correo electrónico y endpoints de empleados.
- Proveedores relaciones a la empresa y sistemas de terceros.
- Infraestructura que no forme parte del objetivo autorizado.
- Eliminación, modificación o extracción innecesaria de información real de clientes.
- Cualquier activo o sistema que no haya sido autorizado formalmente.

3. Autorización y condiciones

Permisos requeridos

- Autorización documentada de Aurora Market para ejecutar la evaluación de seguridad.
- Definición de las URLs, dominios y activos autorizados.
- Identificación de responsables técnicos y contactos de emergencia.
- Autorización expresa para realizar pruebas de explotación controlada.

Condiciones acordadas

- Las pruebas se ejecutarán exclusivamente sobre la aplicación web autorizada.
- Las actividades se realizarán durante horarios de menor actividad para minimizar impactos operativos.
- No se realizarán acciones destinadas a interrumpir deliberadamente la disponibilidad del servicio.

- No se eliminará ni alterará información real de clientes.
- Las pruebas de explotación serán controladas, documentadas y reproducibles.
- Los hallazgos críticos serán comunicados oportunamente al responsable designado por Aurora Market.
- Toda información obtenida durante el pentest será tratada como confidencial.

4. Tipo de Pentest

Se elige la modalidad Grey Box porque el equipo de Ethical Hacking tendrá información parcial sobre Aurora Market, incluyendo el objetivo, alcance y características generales de la aplicación, pero no tendrá al principio un conocimiento completo de su infraestructura ni de su código fuente. Esta opción permite recrear un ambiente realista en el que un atacante tiene información restringida y analizar de manera controlada la seguridad de la aplicación.

5. Planificación del Pentest

Elemento	Planificación
Objetivos	Detectar, validar y registrar las vulnerabilidades y averiguar cómo afectan a Aurora Market y a sus usuarios.
Alcance	Aplicación web autorizada, verificación de identidad, sesiones, usuarios, productos, órdenes y controles de acceso.
Permisos y condiciones	Autorización formal, usuarios de prueba, activos determinados, horario con menos actividad y prohibición de alterar la disponibilidad o los datos reales.
Metodología a utilizar	Guía de pruebas de seguridad web de OWASP (WSTG), complementada con PTES para organizar las etapas de ejecución.
Recopilación de información previa	tecnologías, dominios, URLs, roles, funcionalidades, arquitectura disponible y mecanismos de autenticación.
Recursos necesarios	Burp Suite, Kali Linux, herramientas de análisis, Nmap, ZAP de OWASP y el pentester, quien es el encargado técnico del cliente.
Programación del pentest	Reconocimiento, evaluación de vulnerabilidades, explotación controlada, postexplotación, análisis de resultados e informe.

6. Fases del Pentest

6.1. Reconocimiento

Utilizar métodos de reconocimiento activo controlado y pasivo para determinar las URLs, tecnologías, características, mecanismos de autenticación, puntos de entrada y endpoints de la aplicación.

- Reconocimiento de tecnologías.
- Listado de puntos finales.
- Reconocimiento de parámetros y formularios.
- Inspección de los archivos y directorios que están expuestos.

6.2. Análisis de vulnerabilidades

Examinar la aplicación para detectar vulnerabilidades vinculadas a la autorización, autenticación, validación de entradas, gestión de sesiones, revelación de información y configuraciones que no son seguras.

- Evaluación de OWASP Top 10.
- Evaluaciones de control de acceso.
- Análisis de sesiones y autenticación.
- Análisis de XSS e inyección.
- Evaluación de la divulgación de información.

6.3. Explotación

Verificar de manera controlada las vulnerabilidades detectadas para confirmar si son realmente explotables y evaluar su impacto, evitando alterar la disponibilidad o alterar información verídica.

- Comprobación de elusión de autenticación.
- Exámenes de verificación de acceso.
- Verificación de inyecciones.
- Pruebas XSS supervisadas.
- Ajuste controlado de parámetros.

6.4. Después de la explotación

Establecer el nivel de acceso logrado tras una explotación exitosa y analizar qué información o funciones podrían verse afectadas al utilizar cuentas y datos de prueba.

- Análisis de privilegios adquiridos.
- Localización de datos disponibles.
- Verificación de acceso a otras características.
- Valoración del escalamiento de privilegios.

6.5. Informe

Documentar los hallazgos identificados, evidencias, impacto, nivel de riesgo y recomendaciones de remediación para que Aurora Market pueda corregir las vulnerabilidades.

- Resumen ejecutivo.
- Metodología y alcance.
- Hallazgos y evidencias.
- Nivel de riesgo e impacto.
- Recomendaciones y plan de remediación.
- Conclusiones.

7. Investigación

7.1. Metodología seleccionada: OWASP Web Security Testing Guide (WSTG)

OWASP WSTG es un enfoque dedicado a analizar la seguridad de aplicaciones web. Su diseño facilita la realización de pruebas de forma ordenada en autenticación, autorización, gestión de sesiones, validación de entradas, manejo de errores, configuración y exposición de datos.

7.2. Utilidad para Aurora Market

La metodología es particularmente apta para Aurora Market ya que la plataforma gestiona cuentas de usuarios, datos sobre pedidos y otra información que puede ser sensible. Su uso permitirá detectar riesgos como acceso no permitido, sustracción de cuentas, alteración de transacciones, fallos de entrada y revelación de información.